Análise de arquivo suspeito

Share

exec.pyc

PYC

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Lendo o arquivo para análise estática, sem executá-lo

Vou começar lendo as instruções do skill de leitura de arquivos e depois fazer uma análise estática, sem executar o arquivo em nenhum momento.

Ran 5 commands, read a file

Fiz uma **análise estática**: o arquivo foi lido e desserializado, mas **nunca executado**.

Passo 1: Identificação

- Bytecode Python compilado (`.pyc`) para **CPython 3.13**. O `file` diz "3.12 ou superior", mas os bytes mágicos `f30d0d0a` indicam 3.13.
- 57.929 bytes. SHA-256: `e7c55ad35f526ef8213e68cf1618f62c74134dc3246b815b2850ef7d772a6212`
- O nome interno do script original é um hash (`806c1a41…5457.py`), o que sugere um arquivo gerado automaticamente, e não um projeto com nome próprio.

Passo 2: Estrutura

Há 12 funções, todas de instalação e provisionamento: `install_komari_agent_first` , `install_tm_first` , `force_fix_apt_locks` , `download_with_validation` , `ensure_venv` , `main` , entre outras. Ou seja, é um instalador, não uma biblioteca ou utilitário.

Passo 3: Comportamentos encontrados

1. **Varredura em massa de SSH:** instala o `masscan` e embute quatro scripts (`run_scan.sh` , `ssh_scanner.py` , `filter_files.py` , `ip_port_extractor.py`). O fluxo é varrer faixas de IP, extrair `ip:porta` e testar login SSH em paralelo com usuário e senha fixos. As faixas de IP vêm de `del.sou.pp.ua` , um domínio de terceiro.
2. **Propagação:** um segundo serviço se descreve como *"File Monitor and Propagation Service"*. Ele usa `paramiko` (`SSHClient` com `AutoAddPolicy` , `exec_command` e SFTP) para entrar em outros servidores e implantar o payload (`bendi.py`).
3. **Persistência e furtividade:**

- Diretórios ocultos com prefixo `.sysd-`, que imitam o systemd.
- Serviços systemd rodando como root com `Restart=always`.
- Log oculto em `/var/log/.sysd-monitor.log`.
- O script apaga a si mesmo depois de instalar (`sleep 2 && rm`).
- Executa `killall apt apt-get dpkg` para forçar a instalação.

4. **Software instalado a partir do domínio do atacante:** o **Komari Agent** (monitoramento de servidores) e o **Traffmonetizer** (compartilhamento de banda que gera receita para quem o configura). Ambos são programas legítimos, mas aqui são instalados de forma oculta, e o segundo provavelmente serve para monetizar a máquina da vítima.
5. **Canal de relatório:** token de bot do **Telegram** e chat ID fixos no código, mais um identificador de VPS (`[sup]`) e uma senha fixa passada ao serviço de propagação. Omiti o token e a senha de propósito.

Passo 4: Existe explicação benigna?

Poderia ser uma ferramenta de pentest ou de administração? Não. Uma ferramenta legítima não precisaria de nenhuma destas características:

- se espalhar sozinha para outros servidores;
- se esconder em diretórios imitando o sistema;
- se autodeletar;
- depender de um domínio de terceiros para receber alvos;
- reportar a um bot do Telegram;
- instalar proxyware.

Conclusão: é malware

Trata-se de um **worm/botnet de SSH:** varre a internet, tenta entrar em servidores por credencial, persiste como root, se propaga e monetiza as máquinas infectadas.

Indicadores de comprometimento (IOCs):

- Domínios: `sou.pp.ua` e `del.sou.pp.ua`
- Caminhos: `/usr/lib/.sysd-scan/`, `/var/lib/.sysd-data/`, `/usr/lib/.sysd-monitor`, `/var/log/.sysd-monitor.log`
- Serviços: `scan-runner.service`, `file-monitor.service`
- Telegram: bot ID `7431501378`, chat ID `743493786`

Limitações: não acessei os URLs remotos (sem rede), então não sei o conteúdo exato de `install.sh` e `install_tm.sh`. Também não desmontei os opcodes, porque a versão local do Python é diferente. Mesmo assim, as strings, nomes e fluxo são consistentes entre si e suficientes para o veredito.

Se você encontrou isso em um servidor: não execute o arquivo e considere a máquina comprometida. Isole-a da rede, verifique esses serviços, diretórios e conexões para os domínios acima, troque as credenciais SSH e prefira reinstalar o sistema, já que havia acesso root. Se quiser, posso montar um checklist de verificação e endurecimento do SSH para o seu caso.

Qual é a categoria principal deste malware?

Verificando se há sinais de mineração de criptomoedas ▸

Pela análise que fiz, a categoria principal é **worm (verme) de SSH**. Antes de afirmar o que o malware *não* é (minerador, ransomware, ladrão de dados), vou conferir isso nas strings, porque minha busca anterior não incluía esses termos.

Ran a command ▸

A categoria principal é **worm (verme) de SSH**, ou seja, malware que se espalha sozinho de uma máquina para outra, aqui via SSH.

Por que worm:

- O ciclo é autônomo: varre faixas de IP com `masscan`, testa a mesma credencial em muitos hosts, entra nos que aceitam e implanta uma cópia do payload nesses hosts, que repetem o processo.
- O código se descreve como *"File Monitor and Propagation Service"* e usa `paramiko` (SSH e SFTP) para implantar o payload nos alvos.
- A propagação é a função central. Os outros comportamentos só dão sustentação a ela.

Características secundárias:

- **Botnet:** as máquinas infectadas reportam a um bot do Telegram e podem receber atualizações das listas de alvos (`ip_ranges.txt`, `del.txt`) de um domínio do atacante.
- **Sequestro de recursos (resource hijacking):** a instalação oculta do Traffmonetizer sugere monetização da banda da vítima.
- **Dropper/instalador:** o `.pyc` em si é a etapa inicial que monta toda a infraestrutura (serviços, diretórios ocultos, dependências).

O que ele não parece ser, com base nas strings que inspecionei: não há indício de minerador de criptomoedas, ransomware, ladrão de dados (stealer), DDoS ou rootkit. Isso vale só para o que está dentro do `.pyc`, porque não analisei os scripts remotos (`install.sh`, `install_tm.sh`), que poderiam adicionar outras funções.

Mapeamento aproximado no MITRE ATT&CK: T1046 (descoberta de serviços de rede), T1110.003 (password spraying), T1021.004 (SSH), T1543.002 (serviço systemd), T1564.001 (arquivos ocultos), T1070.004 (autoexclusão), T1102 (comunicação via serviço web, no caso o Telegram) e T1496 (sequestro de recursos).

Em um relatório, eu classificaria como **"SSH worm / botnet com monetização por proxyware"**.